

Web verification scan integration

The web client uses an anonymous signed cookie and a single-use nonce. The cookie identifies repeat activity from the same browser without exposing or storing a hardware identifier. The nonce prevents replay of a captured verification request.

Browser flow

1. Before the first verification, call `POST /api/v1/code-batches/codes/scan-session` with `credentials: 'include'`.
2. The response contains `nonce`, `nonceExpiresInSeconds`, and `sessionExpiresInSeconds`. The API sets the `gve_scanner` cookie; JavaScript must not attempt to read it because it is `HttpOnly`.
3. Send the nonce in the existing verification body:

```
{
  "verificationCode": "1234567890123456",
  "nonce": "nonce-from-scan-session"
}
```

4. Call `POST /api/v1/code-batches/codes/verify` with `credentials: 'include'`.
5. After a successful verification, replace the in-memory nonce with `nextNonce` from the response. It expires after `nonceExpiresInSeconds`.
6. If verification returns `SCAN_NONCE_INVALID` or `SCAN_NONCE_REQUIRED`, request a new scan session and retry once. Never retry indefinitely.

Do not persist the nonce in local storage and do not create a browser fingerprint. The signed browser cookie lasts 30 days and is stored only by the browser. Clearing cookies or using private browsing creates a new anonymous scanner identity.

Cross-origin deployment

The API already permits credentialed CORS requests. If the web application and API are on different sites, set `SCAN_COOKIE_SAME_SITE=none` in Render and keep both origins on HTTPS. If they share the same site, the default `lax` value is preferred.

Set `SCAN_IDENTITY_SECRET` in Render to an independent random secret of at least 32 bytes. The API temporarily falls back to the code activation pepper for compatibility, but production should use a separate key so the two security domains can be rotated independently.

Every relevant `fetch` call must include:

```
credentials: 'include'
```

Mobile clients

Existing mobile verification requests remain compatible when no `gve_scanner` cookie is sent. Mobile clients should send their privacy-safe installation identifier through a dedicated mobile identity field in a later version; they should not emulate the browser cookie.

Risk signals

- Same anonymous scanner and same code: strong repeat signal.
- Same IP and user agent and same code: medium-to-strong signal.
- Same IP only: weak signal.
- Five recent scans of one code: high-frequency signal.
- One scanner checking at least five different codes within ten minutes: rapid multi-code signal.

IP addresses and user agents are supporting indicators, not proof of a person's identity.